Ce qu'il ne faut pas faire

- Utiliser des algorithmes obsolètes, comme les chiffrements DES et 3DES ou les fonctions de hachage MD5 et SHA-1.
- Confondre fonction de hachage et de chiffrement et considérer qu'une fonction de hachage seule est suffisante pour assurer la confidentialité d'une donnée. Bien que les fonctions de hachage soient des fonctions « à sens unique », c'est-à-dire des fonctions difficiles à inverser, une donnée peut être retrouvée à partir de son empreinte. En effet, ces fonctions étant rapides à l'exécution, il est souvent possible de tester automatiquement toutes les possibilités et ainsi de reconnaître l'empreinte.
- Hacher les mots de passe sans faire intervenir un sel[103].

POUR ALLER PLUS LOIN

- Voir la page dédiée sur le site de la CNIL[104].
- L'ANSSI a publié des **guides**[105] pour aider **les développeurs et administrateurs dans leurs choix d'algorithmes cryptographiques, de dimensionnement et d'implémentation**.
- Lors de la réception d'un certificat électronique, **vérifier que le certificat** contient une indication d'usage conforme à ce qui est attendu, qu'il **est valide et non révoqué, et qu'il possède une chaîne de certification correcte** à tous les niveaux.
- **Utiliser des logiciels ou des bibliothèques cryptographiques ayant fait l'objet de vérifications par des tierces parties à l'expertise avérée.**
- Différentes solutions de chiffrement peuvent être utilisées, telles que :
  - les solutions certifiées ou qualifiées par l'ANSSI[106] ;
  - le logiciel VeraCrypt, permettant la mise en œuvre de conteneurs[107] chiffrés ;
  - le logiciel GNU Privacy Guard, permettant la mise en œuvre de la cryptographie asymétrique (signature et chiffrement)[108].
- Pour les autorités administratives, les annexes du référentiel général de sécurité (RGS)[109] s'appliquent, notamment les annexes B1 et B2 concernant respectivement les mécanismes cryptographiques et la gestion des clés utilisées.

103 On appelle « sel » un aléa différent utilisé pour chaque mot de passe stocké.
104 « Comprendre les grands principes de la cryptologie et du chiffrement », cnil.fr
105 « Mécanismes cryptographiques », cyber.gouv.fr
106 « Visa de sécurité », cyber.gouv.fr
107 Par conteneur, il faut comprendre un fichier susceptible de contenir plusieurs autres fichiers.
108 « The Gnu Privacy Guard », gnupg.org
109 « Le référentiel général de sécurité version 2.0 : les documents », cyber.gouv.fr